

Issues, Verbatim Fixes & 30-Day Plan

Every material issue found in the ridereadyguide.com audit, numbered, with ready-to-implement fixes — exact header values, exact code changes, exact copy — followed by a sequenced 30-day plan.

31

NUMBERED ISSUES

10

QUICK WINS

4

PLAN WEEKS

Companion to the Full Audit Report. Grades and full rationale live in that document; this one is the punch list. File paths and line numbers refer to the ridereadyguide.com source repository as of August 28, 2026.

How to Use This Document

Every issue below was independently verified against the site's own source, a fresh production build, or a live browser render — not inferred. Each carries a **QUICK WIN** or **LONGER-TERM** tag reflecting real effort, not urgency: several quick wins matter more than some longer-term items. Read severity from the category and the description, not the tag alone.

On "verbatim." Where a fix is a header value, a config change, or copy, it is given exactly as it should be pasted or typed. Where a fix touches application logic (an ARIA attribute, a focus-management change), the exact file and function are named along with the precise change — implementation-ready, though the final line of code is for whoever holds the file to place correctly given the surrounding code. Every CSS hex value and CSP hash below was independently computed and verified during this audit, not estimated.

Issues are grouped into seven categories: Security Headers, SEO & Structured Data, Performance & Assets, Accessibility, Privacy/Legal/Compliance, Monetization & Ops, and Content & Brand. The 30-Day Plan on the final pages sequences the highest-leverage subset of these into a week-by-week schedule.

Numbered Issues

A · Security Headers

1 No Content-Security-Policy header anywhere in the deployed configuration

QUICK WIN

The repository's only header configuration (`SECURITY_HEADERS` in `src/build.mjs:408-413` , consumed by `buildHeaders()` at line 457 to write `dist/_headers` , and mirrored in `vercel.json`) sets no `Content-Security-Policy` . Given the site makes zero third-party requests at build time, a tight policy is low-risk to adopt. The policy below was derived from — not guessed at — the actual shipped markup: it was verified that the site uses exactly one inline `<script>` (the theme-flash-prevention snippet in `src/templates/layout.mjs` , identical on every page) and does use inline `style="..."` attributes (105 of 379 pages) but zero `<form>` elements.

FIX — ADD TO THE `SECURITY_HEADERS` OBJECT AT `SRC/BUILD.MJS:408`

```
const SECURITY_HEADERS = {
  'X-Content-Type-Options': 'nosniff',
  'Referrer-Policy': 'strict-origin-when-cross-origin',
  'X-Frame-Options': 'SAMEORIGIN',
  'Permissions-Policy': 'geolocation=(), microphone=(), camera=(), interest-cohort=()',
  'Content-Security-Policy': "default-src 'self'; script-src 'self' 'sha256-
CjLON09GEVmvhXJxMsZZe1MjXByFDF+3aeV+tnp5UjQ='; style-src 'self' 'unsafe-inline'; img-src 'self';
font-src 'none'; connect-src 'self'; manifest-src 'self'; worker-src 'self'; object-src 'none';
base-uri 'self'; form-action 'self'; frame-ancestors 'self'; upgrade-insecure-requests",
}
```

The `sha256-...` value is the exact, verified hash of the current inline theme-bootstrap script's byte content — it will need recomputing only if that specific inline script's text ever changes. JSON-LD `<script type="application/ld+json">` blocks are exempt from `script-src` under the CSP spec (they are data, not executable script) and need no allowance. `style-src 'unsafe-inline'` is required today because of the 105 pages using inline `style="..."` attributes — tightening this to hashes is a longer-term follow-up, not a blocker to shipping the rest of the policy now. Because this object feeds every header block `buildHeaders()` generates, this two-line change applies the policy to every route in one place, consistent with the file's existing "repeat the security block everywhere" design. Deploy to a preview environment first and check the browser console on one page of each type (home, park hub, ride detail, tool, legal) for CSP violation warnings before promoting to production.

2

No Strict-Transport-Security header anywhere in the deployed configuration

QUICK WIN

Same root cause as Issue 1 — `SECURITY_HEADERS` has no HSTS entry, and this audit could not verify from the repository alone whether Cloudflare's zone-level "Always Use HTTPS" / HSTS dashboard toggle is separately enabled (that setting lives outside this codebase). Ship both, since they are independent controls and a static-generator fix cannot substitute for the dashboard setting if the dashboard one is off.

FIX, STEP 1 — ADD TO THE SAME OBJECT, START CONSERVATIVE

```
'Strict-Transport-Security': 'max-age=15552000; includeSubDomains',
```

FIX, STEP 2 — AFTER ~2-4 WEEKS WITH NO ISSUES, ESCALATE

```
'Strict-Transport-Security': 'max-age=63072000; includeSubDomains; preload',
```

15552000s = 180 days (safe rollout value); 63072000s = 2 years (the value expected for HSTS preload-list submission). Adding the `preload` directive to the header does not itself enroll the domain — that additionally requires submitting ridereadyguide.com at hstspreload.org once the 2-year value has been live and confirmed working. **Also confirm directly in the Cloudflare dashboard** (SSL/TLS → Edge Certificates → HSTS) since that setting is independent of this repository and this audit could not verify it from here.

B · SEO & Structured Data

3

Zero pages emit `og:image` or `twitter:image` — no social-share image anywhere on the site

QUICK WIN

The templating logic is already correct and tested (`src/templates/layout.mjs:44-50`): it emits `og:image`, `og:image:width/height`, `twitter:image`, and upgrades `twitter:card` to `summary_large_image` automatically the moment `site.socialImage` is non-null. It is null today only because the two backing image files were never added. This is the single highest-leverage fix in this audit — code-complete, waiting on two assets.

FIX — ADD THESE EXACT FILES (PER THE DOCUMENTED CONVENTION IN `ASSETS/IMG/PHOTOS/README.MD` AND THE SLOT SPEC IN `DATA/DISNEY/SITE.JSON` → `PHOTOS`)

```
# Social card — 1.91:1, budget ~80KB. This alone flips og:image/twitter:image on across all 379 pages.
assets/img/photos/social-card-640.avif (+ .webp, .jpg)
assets/img/photos/social-card-1280.avif (+ .webp, .jpg)

# Hero — budget ≤120KB AVIF at 1920w. Atmospheric only per docs/LOVABLE-VISUAL-OVERHAUL.md's own
# guardrails: no faces presented as real guests, no castle silhouette, no character imagery.
assets/img/photos/hero-fireworks-640.avif (+ .webp, .jpg)
assets/img/photos/hero-fireworks-1280.avif (+ .webp, .jpg)
assets/img/photos/hero-fireworks-1920.avif (+ .webp, .jpg)
```

Record provenance (generator + prompt, or licence + source) in a `CREDITS.md` beside the images per the documented rights policy, then `npm run build` — no code change required. This single fix also resolves the Twitter-card-type limitation and directly improves Dimension 1 (Visual Design) and Dimension 6 (SEO) simultaneously.

4

Sitemap lists 13 URLs that are simultaneously marked `noindex`

QUICK WIN

All 13 `/events/<slug>/20XX/` dated-edition pages carry `<meta name="robots" content="noindex, follow">` yet still appear in `sitemap.xml` (e.g. `events/oogie-boogie-bash/2025/`). The sitemap filter in `src/build.mjs:235` never checks the page's own `noindex` flag.

FIX — `SRC/BUILD.MJS:235`

```
// before:
.filter((p) => !p.url.endsWith('.html') && p.url !== '/offline/')
// after:
.filter((p) => !p.url.endsWith('.html') && p.url !== '/offline/' && !p.noindex)
```

5 Sitemap `<lastmod>` is one hardcoded date for all 377 URLs

LONGER-TERM

`src/build.mjs:238` emits the literal string `<lastmod>2026-07-01</lastmod>` for every page, even though a real per-page `modified` date already exists and correctly feeds each page's `WebPage.dateModified` JSON-LD field one function away. The sitemap is the one place this real signal doesn't reach.

FIX — `SRC/BUILD.MJS`, **INSIDE** `BUILDSITEMAP()`

```
// replace the hardcoded literal with the same per-page date already computed
// for WebPage.dateModified (thread it through the same `p` object buildSitemap already iterates):
<lastmod>${p.modified || '2026-07-01'}</lastmod>
```

Keep the current literal as a fallback default only, not the primary value, so a page missing a modified date still emits something valid rather than breaking the build.

6 Five page titles exceed the site's own 66-character budget

QUICK WIN

`composeTitle()` (`src/templates/layout.mjs:22-28`) correctly drops the descriptor tail and the brand suffix when a title runs long, but never truncates the mandatory page title itself, so a handful of long attraction names still overflow and risk truncation in search results.

FIX — SHORTEN THESE 5 DATA-LAYER TITLES (IN THE RELEVANT `ATTRACTIONS.JSON` ENTRIES), OR ADD A HARD-TRUNCATION FALLBACK IN `COMPOSETITLE()` FOR ANY FUTURE OUTLIER

```
82 chars → For the First Time in Forever: A Frozen Sing-Along Celebration (Hollywood Studios)
70 chars → The Little Mermaid ~ Ariel's Undersea Adventure (California Adventure)
70 chars → Expedition Everest - Legend of the Forbidden Mountain (Animal Kingdom)
67 chars → Ghirardelli Soda Fountain and Chocolate Shop (California Adventure)
67 chars → Guardians of the Galaxy - Mission: BREAKOUT! (California Adventure)
```

Suggested trims: drop the parenthetical park qualifier where the ride list already provides park context (e.g. "For the First Time in Forever: A Frozen Sing-Along Celebration" alone is 64 chars, back under budget), rather than shortening the attraction's actual name.

7 The staleness clock (`BUILD_MONTH`) is a hand-maintained literal with no drift guard

LONGER-TERM

`BUILD_MONTH = '2026-07'` in `src/lib/staleness.mjs:20` gates every staleness banner, sitemap demotion, and `Event` JSON-LD eligibility decision sitewide. It was roughly one calendar month behind the real date at time of audit, and nothing currently fails a build if it drifts further.

FIX — ADD A SOFT CHECK TO `SCRIPTS/VALIDATE.MJS` OR THE CI WORKFLOW

```
// fail loud (or at least warn) if BUILD_MONTH is more than N months behind the real clock:
const monthsBehind = ordinal(new Date().toISOString().slice(0,7)) - ordinal(BUILD_MONTH)
if (monthsBehind > 1) throw new Error(`BUILD_MONTH is ${monthsBehind} months stale - bump it before this build is trusted.`)
```

C · Performance & Assets

8 The Food Tracker page is 489 KB — sixteen times the site's median page weight LONGER-TERM

Independently confirmed by two methods (static file size and a live browser rendering the page at 42,170px tall):
`tools/food-tracker/` inlines all 2,016 `.food-card` blocks (252 items × 6 parks + park sections) on first load, even though a guest is only ever at one park at a time and their selection state already lives in `localStorage`.

FIX — SCOPE INITIAL RENDER TO THE VISITOR'S STORED/SELECTED PARK

```
// on load, read the existing localStorage state used for filtering, and either:  
// (a) render only the selected park's cards server-side, with the "every park" view  
//     available behind the existing park filter as a progressive fetch, or  
// (b) keep one HTML document but move the 5 non-active parks' card markup behind  
//     a <template> tag, hydrated client-side only when that park filter is chosen.
```

Either approach preserves the "works offline, no signal needed" guarantee (the SW already precaches this page) while cutting the default payload roughly 6×. Re-verify the precache list in `assets/sw.js` still covers whichever markup ships by default after this change.

9 CSS/JS cache-busting is manual, not content-hashed, under a 1-year immutable cache LONGER-TERM

`ASSET_VERSION = '1'` (`src/templates/layout.mjs:5`) and the service worker's `version = `2026.07.01-${'$'}${pages.length}`` (`src/build.mjs:558`) are both hand-maintained constants. Combined with `Cache-Control: public, max-age=31536000, immutable` on `/assets/*`, a shipped CSS/JS change is invisible to a returning visitor for up to a year unless a developer remembers to bump both by hand.

FIX — DERIVE BOTH FROM A BUILD-TIME CONTENT HASH

```
// src/templates/layout.mjs — replace the literal with a hash of the built file:  
import { createHash } from 'node:crypto'  
const ASSET_VERSION = createHash('sha256').update(mainCssContent).digest('hex').slice(0, 10)  
// src/build.mjs — derive the SW version the same way instead of a date literal:  
const version = createHash('sha256').update(allAssetContents.join('')).digest('hex').slice(0, 10)
```

10 Service worker's background revalidation fetch doesn't bypass the HTTP cache QUICK WIN

The cache-first-with-background-revalidate strategy in `assets/sw.js` issues its "refresh in the background" fetch without `{cache: 'reload'}`. Given the `immutable` header on the same assets, that fetch is likely satisfied straight from the browser's HTTP cache — making the revalidation step a no-op unless the URL itself changes. Compounds Issue 9.

FIX — ASSETS/SW.JS, THE RUNTIME-CACHE FETCH

```
// before:  
fetch(request).then((response) => cache.put(request, response))  
// after:  
fetch(request, { cache: 'reload' }).then((response) => cache.put(request, response))
```

11 No Cache-Control is set for HTML documents

QUICK WIN

`_headers` sets explicit caching for `/assets/*`, `/sw.js`, `/search-index.json`, and `/maps/*`, but the catch-all `/*` block carries only security headers — HTML gets whatever the hosting platform defaults to, undocumented in the repository itself.

FIX — ADD A RULE TO `CACHE_RULES` IN `SRC/BUILD.MJS:401`

```
{ path: '/*.html', vercel: '/(.*).html', value: 'public, max-age=300, must-revalidate' },  
// or, if the build's clean-URL routing makes an extension-based rule impractical on Pages,  
// add the header explicitly to the `/*` block inside buildHeaders() instead.
```

12 Six downloadable park-map PNGs are stale and inefficiently encoded

QUICK WIN

The project's own `npm run audit:site` flags all six park map PNGs (magic-kingdom, epcot, hollywood-studios, animal-kingdom, disneyland-park, california-adventure) as older than their source geometry/styling. Separately, these are large for what they contain: flat-color illustrated maps at 1.3–5.2 MB each as PNG, a poor codec for this content.

FIX

```
npm run maps:png # regenerates all 6 from current geometry – closes the staleness flag today
```

Longer-term: re-encode the map-plate pipeline to output WebP or AVIF alongside PNG for browsers that support it; a flat-color illustrated map typically compresses 60-80% smaller in either format with no visible quality loss. These are download-only assets (linked via `<a download>`, never embedded), so this does not affect normal page-load performance — it only matters for the visitors who explicitly request the file.

D · Accessibility

13 Light-theme --accent fails WCAG AA for normal text (4.31:1, needs 4.5:1)

QUICK WIN

Independently computed via the WCAG relative-luminance formula and re-verified during synthesis: `--accent: #a9660f` against `--paper: #faf8f4` is 4.31:1. It is used at sub-large-text size for `.kicker`, `.hero__eyebrow`, and `.nearmiss__title` (`assets/css/main.css:26, 205-212, 330-333, 937-940`) — a recurring pattern visible on nearly every page. The dark-theme value (`#e9b264`, 10.12:1) is unaffected.

FIX — `ASSETS/CSS/MAIN.CSS:26`

```
/* before: */ --accent: #a9660f;
/* after:  */ --accent: #8f5709; /* verified 5.60:1 against --paper — clears AA with margin */
```

14 Height Checker — the flagship interactive tool — is silent to screen readers

LONGER-TERM

Zero `aria-live / role="status"` anywhere in the Height Checker's markup (`src/pages/tools.mjs:214-233`) or its render function (`assets/js/height-checker.js:45-88`). Dragging the slider updates the visible numbers and ride lists but announces nothing — the site's other tool, the Food Tracker, gets this exact pattern right via a `role="status"` element wired to real state changes.

FIX — `SRC/PAGES/TOOLS.MJS`, THE RESULTS CONTAINER AND VALUE SPANS

```
<div data-height-results aria-live="polite">...</div>
<span data-height-value>...</span> → wrap this cluster's parent in role="status" aria-
live="polite"
```

Debounce the live-region update in `height-checker.js`'s `render()` (e.g. ~400ms after the last `input` event) so a screen reader announces the settled value rather than every intermediate tick while dragging.

15 Search dialog asserts `aria-modal="true"` without an actual focus trap

LONGER-TERM

`layout.mjs:99` marks the search panel `role="dialog" aria-modal="true"`, but `initSearch()` in `app.js:140-221` has no `Tab`-cycling handler, so `Shift+Tab` from the search input can move focus into the footer sitting behind the backdrop.

FIX — `APP.JS`, INSIDE `INITSEARCH()`

```
// on open: capture the panel's focusable elements; on keydown Tab/Shift+Tab at the first/last
// one, wrap focus back around. On close: return focus to the element that opened the dialog
// (already partially done for the mobile nav pattern elsewhere in this same file — reuse it).
```

16 Search results list has no `aria-activedescendant`

QUICK WIN

Arrow-key highlighting in the `role="listbox"` search results (`app.js:187-194`) toggles a custom `data-active` attribute with no corresponding `aria-activedescendant` on the input, so a screen-reader user gets no spoken feedback on which result is currently highlighted.

FIX — `APP.JS`, INSIDE THE `ARROW-KEY MOVE()` HANDLER

```
searchInput.setAttribute('aria-activedescendant', activeOption.id)
```

17 `--line-strong` border color falls under the 3:1 non-text contrast guideline

LONGER-TERM

1.62:1 (light) / 1.86:1 (dark) against its typical background, used as a resting border on `.chip`, `.btn--ghost`, and table-row dividers. Low urgency — these elements already carry text and padding affordances that convey their boundary independent of the border — but worth a pass if the token is ever relied on as the sole boundary cue.

FIX — `ASSETS/CSS/MAIN.CSS`, **TOKEN BLOCK**

```
--line-strong: #b8ae9a; /* light */
--line-strong: #41504b; /* dark */
```

E · Privacy, Legal & Compliance

18 No attorney has reviewed the legal pages yet

LONGER-TERM

Both `/privacy/` and `/terms/` self-disclose as good-faith, non-lawyer drafts — a candid and correct thing to state, but the project's own `docs/LAUNCH.md` already lists this as a blocker "nothing ships until" item, ahead of any advertising/analytics activation.

FIX

Commission a one-time attorney review of `/privacy/`, `/terms/`, `/affiliate-disclosure/`, and the image-rights policy before enabling analytics, ads, or scaling EU/UK traffic. Update the self-disclosure banner and the page's "last updated" date once complete.

19 Privacy policy makes no Global Privacy Control (GPC) commitment

QUICK WIN

The Rights section correctly states the site currently sells or shares no personal information, but doesn't commit to honoring the GPC browser signal automatically if that ever changes — an increasingly expected CPRA-adjacent practice.

FIX — ADD TO `/PRIVACY/`, "YOUR RIGHTS" SECTION (VERBATIM COPY, READY TO PASTE)

```
This site currently sells or shares no personal information, so there is nothing to opt out of.  
If that changes, we will honor the Global Privacy Control (GPC) browser signal as a valid  
CCPA/CPRA opt-out automatically, with no action required from you.
```

20 Privacy policy doesn't state the host's log-retention period

QUICK WIN

The "What our host necessarily sees" section correctly describes what's logged (IP, requested page, user agent, timestamp) but not for how long — a small, closeable specificity gap in an otherwise unusually specific policy.

FIX — ADD TO THAT SECTION (FILL IN THE REAL CLOUDFLARE PAGES LOG-RETENTION FIGURE)

```
Our hosting provider retains raw access logs for [N] days before automatic deletion;  
we do not extend that retention ourselves.
```

21 Contact is mailto-only, with no fallback channel

LONGER-TERM

`/contact/` links `corrections@` and `hello@ridereadyguide.com` only. The site publicly commits to a three-working-day acknowledgement SLA on corrections, which is harder to guarantee for a reader whose mail client isn't configured (common on mobile) with no alternate path in.

FIX

Add a lightweight web form as a secondary channel (a static form service or a simple serverless endpoint is sufficient — this does not require standing up a database). If a CSP is adopted per Issue 1, remember `form-action 'self'` is already included to support this.

22 `audit.mjs` doesn't regression-test the FTC disclosure-pairing guarantee

QUICK WIN

The guarantee that a sponsored link never renders without its disclosure is real today — verified directly in shipped HTML — but rests entirely on nobody refactoring the single `affiliateBox()` component that enforces it. The build's own QA script only checks for the unaffiliated-disclaimer string, not this pairing.

FIX — ADD TO `SCRIPTS/AUDIT.MJS`

```
if (/rel="sponsored/.test(html) && !/affiliate__disclosure/.test(html)) {  
  fail(page, 'sponsored link with no disclosure block')  
}
```

23 Amazon affiliate is described as active but zero links render anywhere

QUICK WIN

The affiliate-disclosure page names "Amazon Associates — park gear on the packing recommendations" as a live relationship, and `data/disney/site.json` fully configures it with the correct `rel="sponsored nofollow noopener"`, but a site-wide grep found zero `amazon.com` links in any of the 379 built pages. Low risk (disclosing an unused relationship, not concealing a live one) but a real say/do gap.

FIX — EITHER SHIP IT OR STOP DESCRIBING IT AS ACTIVE

Preferred: wire the existing "gear" affiliate into the existing `guides/what-to-pack/` guide, which is exactly the page this relationship was configured for and is already live — see Issue 29 / Week 3 of the plan below. If that's not happening this cycle, temporarily soften the disclosure copy to describe the relationship as "reserved for our packing guide" rather than active.

F · Monetization & Ops

24 No ads.txt file

LONGER-TERM

Expected and correct for the site's current state (no ad network is live yet), but worth tracking so it isn't forgotten at the moment an AdSense/Mediavine account is approved — a missing `ads.txt` at that point directly costs fill rate and CPMs.

FIX — PREPARE NOW, PUBLISH THE DAY AN AD ACCOUNT IS APPROVED

```
google.com, pub-XXXXXXXXXXXXXXXX, DIRECT, f08c47fec0942fa0 # AdSense, once approved
```

25 No consent management platform wired yet

LONGER-TERM

Correctly sequenced as a blocker in `docs/LAUNCH.md`: personalized advertising can constitute "sharing" under the CPRA, and GDPR requires consent before non-essential cookies/analytics. `site.analytics.enabled` should not flip to `true` before a CMP is in place.

FIX

Both major ad networks under consideration (AdSense, Mediavine) provide a CMP as part of onboarding — use it, verify it fires before any analytics/ad script, then flip the flag. See Week 4 of the plan.

26 A second, parallel hosting config (`vercel.json`) risks silent drift from the canonical `_headers`

LONGER-TERM

Currently consistent with `dist/_headers`, and generated from the same `SECURITY_HEADERS` / `CACHE_RULES` source objects — so Issues 1 and 2's fixes will automatically apply to both. The risk is structural: two deploy targets means two places a future manual header edit can diverge, and `docs/LAUNCH.md` names Cloudflare Pages as the only canonical target.

FIX

If Vercel is not an active or planned deploy target, remove `vercel.json` and the `buildVercelConfig()` generator to eliminate the drift surface entirely. If it's intentionally kept as a fallback option, add a one-line comment at the top of `buildVercelConfig()` stating that and confirming it's still generated from the shared source objects, not hand-maintained separately.

G · Content & Brand

27 Zero photography ships anywhere on the site

QUICK WIN

Cross-referenced with Issue 3 — same root cause, different lens. This is a content/brand issue as much as an SEO one: every hero, card, and social share is currently text-only. See Issue 3 for the exact file fix; listed again here because it is the single highest-leverage item in the entire audit and belongs in both categories.

FIX

See Issue 3. Budget and rights guardrails are already fully specified in `docs/LOVABLE-VISUAL-OVERHAUL.md` and `assets/img/photos/README.md` — this is an asset-production task, not an engineering one.

28 Placeholder "editorial team" byline instead of a real author identity

LONGER-TERM

Flagged in the project's own words (`docs/LAUNCH.md`): "the weakest thing on the site." A named author with genuine trip history is a real E-E-A-T signal this content — which is specific and opinionated enough to support one — currently forfeits.

FIX

Add a real name, a short bio establishing genuine firsthand park experience, and (optionally) a byline line on ride/guide pages, to `/about/` and `data/disney/site.json`'s author/editorial fields.

29 Podcast pipeline is fully built but has shipped zero episodes

LONGER-TERM

Not a defect — `hasPodcast` correctly stays `false` with an empty episode list, so there's no dangling `<link rel="alternate">` or 404. But it is real, currently-idle engineering investment (a complete RSS 2.0 + iTunes-namespaces generator with byte-length/duration-gated enclosures).

FIX

Either ship episode 1 (activates automatically once real audio + duration data exist in `data/disney/site.json`) or explicitly mark it deferred in planning docs so it isn't mistaken for broken.

30 PWA manifest has no screenshots array

LONGER-TERM

Minor polish item: a `screenshots` array in `manifest.webmanifest` produces a richer install prompt on platforms that support it (notably desktop Chrome/Edge). Blocked in practice on Issue 27/3 — screenshots showing a photography-complete UI are more worth shipping than screenshots of the current state.

FIX

Add a `screenshots` array with 1-2 real UI captures once the photography pass (Issue 3/27) lands.

31**Google Search Console / Bing Webmaster Tools submission status unconfirmed****QUICK WIN**

This audit's live search-index queries confirm the site is being crawled and indexed, but `docs/LAUNCH.md` still lists formal sitemap submission to both consoles as an open pre-launch action, and this audit has no access to either console to verify coverage/impression data directly.

FIX

Confirm or complete: submit `https://ridereadyguide.com/sitemap.xml` in both Google Search Console and Bing Webmaster Tools; run the Rich Results Test against one attraction page, one park hub, and one guide as the project's own checklist already specifies.

30-Day Plan

Sequenced for a small team at roughly 8-10 hours/week — above the documented 2-5 hour/week steady-state maintenance budget, since this is a one-time launch-completion push, not the new normal. Technical quick wins front-load because they're cheap and compound; the photography pass sits in Week 2 because it is the highest-leverage single item and everything downstream of it (social sharing, PWA screenshots, brand feel) benefits from landing early rather than last. Content-authority work is sequenced last, deliberately: it compounds over months, so a two-week head start doesn't matter as much as making sure the technical foundation it will be measured against (indexing, social sharing, security posture) is already solid first.

Week 1 — Days 1–7 · Close the free technical debt

Day	Task	Issue
1	Add Content-Security-Policy and Strict-Transport-Security headers; deploy to preview, smoke-test console for CSP violations across one page of each type	#1, #2
1	Confirm Cloudflare zone-level HSTS/Always-Use-HTTPS dashboard setting matches the new header	#2
2	Fix sitemap <code>noindex</code> filter bug and wire real per-page <code>lastmod</code>	#4, #5
2	Trim the 5 overlong page titles	#6
3	Run <code>npm run maps:png</code> to refresh the 6 stale map plates	#12
3	Fix the light-theme <code>--accent</code> contrast value	#13
4	Add the SW <code>{cache: 'reload'}</code> fix and an HTML <code>Cache-Control</code> rule	#10, #11
4	Add the FTC disclosure-pairing regression check to <code>audit.mjs</code>	#22
5	Add GPC commitment + host log-retention line to the privacy policy	#19, #20
5–6	Confirm/complete GSC and Bing Webmaster Tools sitemap submission; run the Rich Results Test on 3 page types	#31
7	Decide and act on <code>vercel.json</code> (remove, or document as intentional fallback)	#26

Week 2 — Days 8–14 · The photography pass, and the two silent-tool fixes

Day	Task	Issue
8–11	Produce or license the two documented photo slots (hero, social card) within their stated budgets and rights guardrails; record provenance	#3, #27
12	Ship the images, rebuild, verify <code>og:image</code> / <code>twitter:image</code> render correctly on a Facebook/Twitter/Slack link-preview debugger for 3 page types	#3, #27
13	Add <code>aria-live</code> to the Height Checker's result container and value spans, debounced	#14
13	Add the focus trap and <code>aria-activedescendant</code> to the search dialog	#15, #16

14	Manual screen-reader pass (VoiceOver or NVDA) on the Height Checker and search dialog to confirm both fixes actually announce correctly	#14, #15, #16
----	---	---------------

Week 3 — Days 15–21 · Performance completion + monetization follow-through

Day	Task	Issue
15–17	Rework the Food Tracker to scope initial render to one park, with the full-list view behind the existing filter	#8
18	Move CSS/JS and service-worker versioning to a build-time content hash	#9
19	Wire the Amazon "gear" affiliate into the existing <code>guides/what-to-pack/</code> guide (the page it was configured for); re-verify the disclosure-pairing check from Week 1 catches it correctly	#23
20	Add a real named author identity and bio to <code>/about/</code>	#28
21	Real-device check: install to a phone home screen, disable network, confirm the Food Tracker and one park map still open (the project's own still-open launch checklist item) — re-run after the Week 3 Food Tracker changes specifically	#8, PWA

Week 4 — Days 22–30 · Legal completion + topical-authority expansion

Day	Task	Issue
22	Commission the attorney review of <code>/privacy/</code> , <code>/terms/</code> , <code>/affiliate-disclosure/</code> (external dependency — start it now even if it closes after day 30)	#18
23	Add the lightweight web-form contact fallback	#21
24	Evaluate and select a CMP (bundled with whichever ad network is chosen) and a cookieless analytics provider matching the site's own "privacy-first analytics" language; do not flip <code>site.analytics.enabled</code> yet	#25
25	Prepare (do not yet publish) <code>ads.txt</code> content pending ad-account approval	#24
26–29	Content: promote 2-3 standalone attraction pages from "major" tier per the project's own promotion criteria, prioritizing attractions with the strongest independent search interest; draft 1 new comparison page filling a gap in the existing 10-comparison set	Content authority
30	Re-run <code>npm run check</code> (tests + build + audit) end-to-end; re-screenshot desktop/mobile/light/dark to confirm the month's changes render correctly everywhere before calling this cycle closed	All

Monetization & Affiliate Opportunity Mapping

Recommendations are deliberately conservative and in-voice — this site's stated ethos is "we only link to sellers we would use ourselves," and that discipline is a real asset worth protecting from affiliate-bloat creep.

- **Wire the existing Amazon "gear" affiliate into the existing packing guide (Week 3).** The highest-confidence, lowest-effort opportunity in this audit: the relationship is already configured, disclosed, and legally covered — it is simply not yet linked from the one page it was built for.
- **Sequence AdSense before Mediavine, exactly as the project's own plan already states.** This audit concurs with that sequencing. Before the first ad renders, reserve fixed slot dimensions in the CSS grid — this site currently has zero CLS risk from images (there are none) and zero from ads (there are none yet); the first ad unit is the first real CLS threat this site will face, and it is far cheaper to reserve the space now than retrofit it after a Core Web Vitals regression.
- **A cookieless, EU-hosted analytics provider (Plausible/Fathom-class) when the CMP lands.** Matches the site's own "privacy-first analytics" language in `site.json` without requiring a policy rewrite beyond flipping the existing conditional, and finally gives the team real data to prioritize which of the site's "expected"/"historical" pages to re-verify first.
- **Do not add a second ticket/package affiliate to compete with the two already live.** Undercover Tourist and Get Away Today are both correctly disclosed and already cover the category; a third competing offer in the same vertical would read as exactly the "affiliate-driven rankings" the homepage explicitly promises visitors this site does not do.

Quick-Win Checklist

The ten items tagged Quick Win across this document, in one place.

- | | |
|--|---|
| ☐ #1 — Add CSP header | ☐ #12 — <code>npm run maps:png</code> |
| ☐ #2 — Add HSTS header (+ confirm Cloudflare dashboard) | ☐ #13 — Fix <code>--accent</code> contrast |
| ☐ #3 / #27 — Ship the two photo assets | ☐ #16 — <code>aria-activedescendant</code> |
| ☐ #4 — Fix sitemap noindex filter | ☐ #19 / #20 — Privacy policy additions |
| ☐ #6 — Trim 5 overlong titles | ☐ #22 — audit.mjs disclosure-pairing check |
| ☐ #10 — SW <code>{cache: 'reload'}</code> fix | ☐ #23 — Wire or soften Amazon affiliate |
| ☐ #11 — HTML Cache-Control rule | ☐ #31 — Confirm GSC/Bing submission |